Министерство науки и высшего образования Российской Федерации

федеральное государственное бюджетное образовательное учреждение высшего образования
НАЦИОНАЛЬНЫЙ ИССЛЕДОВАТЕЛЬСКИЙ МОРДОВСКИЙ ГОСУДАРСТВЕННЫЙ УНИВЕРСИТЕТ им. Н.П. ОГАРЁВА
(ФГБОУ ВО «МГУ им. Н.П. Огарёва»)

Факультет математики и информационных технологий

ОТЧЁТ О ЛАБОРАТОРНОЙ РАБОТЕ №2

по дисциплине: Разработка и реализация программных систем защиты информации

ЗАЩИТА СИСТЕМЫ ТРЁХМЕРНОЙ ВИЗУАЛИЗАЦИИ ТОПОЛОГИЙ

Автор отчёта о лабораторной работе _____ Е. А. Рыбина
подпись, дата

Обозначение лабораторной работы ЛР–02069964–09.04.04–11–26

Направление подготовки 09.04.04 Программная инженерия

Руководитель работы
канд. физ-мат. наук, доц. _____ С. А. Фирсова
подпись, дата

Саранск 2026

СОДЕРЖАНИЕ

ВВЕДЕНИЕ 3
1 Границы доверия и проверки 4
2 Матрица контроля доступа 6
3 План шифрования и управления ключами 8
4 Схема аудита 10
5 План отказоустойчивости 11
ЗАКЛЮЧЕНИЕ 13

ВВЕДЕНИЕ

В первой работе рассмотрена система трёхмерной визуализации крупномасштабных сетевых топологий. Клиентское устройство отображает граф и выполняет расчёт расположения узлов; сервер приложений проверяет запрос, выбирает сегмент сети и передаёт данные порциями; база данных хранит узлы, связи и метрики. Система рассчитана в том числе на слабые устройства, поэтому ограничение вычислительной нагрузки является частью защиты.

Цель работы — определить границы доверия, правила доступа к топологиям, защиту данных и ключей, аудит действий и безопасную реакцию на отказ компонентов. Рассматривается развёртывание в сети организации без предположения об использовании конкретного облака. Если система будет размещена в облачной среде, управление ключами и аудит дополнительно настраиваются средствами выбранной платформы.

1 Границы доверия и проверки

Низкое доверие включает интернет, загружаемые файлы топологии и любые непроверенные данные. Среднее доверие включает рабочую сеть и аутентифицированные клиентские устройства, но сетевое расположение само по себе не даёт права читать сегменты. Высокое доверие образуют серверная логика авторизации и база данных, доступная только серверу. Браузерный клиент остаётся недоверенным для принятия решений о доступе: фильтрация и ограничения повторно проверяются на сервере.

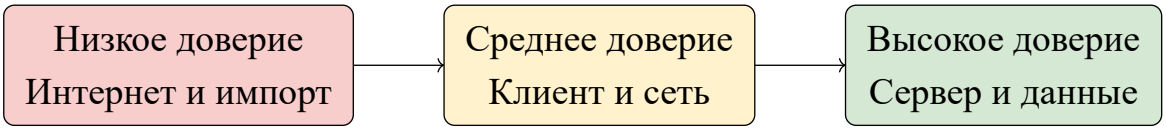


Рисунок 1 – Уровни доверия системы визуализации топологий

Таблица 1 – Проверки переходов через границы доверия

Граница	Проверки	Действие при ошибке
Интернет → клиент	TLS 1.3; проверка сертификата сервера; безопасные настройки браузера; запрет смешанного содержимого	Соединение не устанавливается; причина записывается в журнал
Клиент → сервер	Аутентификация пользователя; срок сессии; роль и принадлежность сегмента; проверка идентификатора запроса, размера и частоты	Запрос отклоняется; лимит попыток; без выдачи данных соседнего сегмента
Импорт → сервер	Лимит размера и числа узлов/связей; проверка формата, типов, диапазонов и циклов; безопасный разбор	Файл отклоняется до записи; ошибка импорта журналируется
Сервер → база	Отдельная учётная запись; разрешённая схема; параметризованные запросы; фильтр по организации и сегменту	Операция отменяется; прямой доступ клиента к БД отсутствует

Сервер дополнительно ограничивает время и память обработки графа, число параллельных запросов и размер порции данных. Метаданные узлов и связей считаются недоверенным содержимым: перед выводом в HTML или

всплывающей подсказке они экранируются; импортированный текст не интерпретируется как HTML или сценарий. Графический клиент проверяет размеры буферов и значения координат до передачи данных WebGL.

2 Матрица контроля доступа

Применяется сочетание RBAC и ABAC. Роль задаёт допустимые операции, а атрибуты уточняют их по организации, проекту и сетевому сегменту. Сервер извлекает область доступа из проверенной учётной записи, а не из произвольного идентификатора, присланного интерфейсом. При отсутствии правила действует отказ.

Таблица 2 – Доступ пользовательских ролей к данным

Роль	Ресурс	Действие	Условие и ограничение
Администратор организации	Пользователи и проекты организации	Создавать; назначать права; отзывать	Только своя организация; повторная аутентификация; изменение роли записывается в аудит
Аналитик сети	Топология и метрики сегмента	Просматривать; фильтровать; экспортировать	Сегмент включён в назначенные проекты; экспорт ограничен политикой организации и аудируется
Наблюдатель	Разрешённая топология	Только просмотр	Только назначенные проекты; без импорта, изменения и экспорта
Аудитор безопасности	Журнал событий	Читать; выгружать	Без редактирования и удаления; выгрузка и поиск событий фиксируются отдельно

Таблица 3 – Доступ сервисов и модулей системы

Субъект	Ресурс	Операция	Ограничение
Сервис API	База топологий	Читать; записывать	Только от имени сервера; права БД ограничены нужными таблицами
Модуль импорта	Временная область загрузки	Проверять; подготовить импорт	Изолированный процесс; лимит ресурсов; публикация только после проверки и подтверждения
Клиентский визуализатор	Порция топологии	Получить; отрисовать	Только выданный сервером сегмент; клиент не получает учётные данные БД

Для решения по каждой операции используются субъект, действие, ресурс и контекст: идентификатор организации, проекта и сегмента, роль, срок сессии, тип операции и лимит экспорта. Администратор одной организации не получает доступа к данным другой. Сервис импорта изолирован от основной базы до завершения проверок; визуализатор получает только данные, разрешённые текущему пользователю.

3 План шифрования и управления ключами

Топологии, адреса узлов, описания портов, метрики и результаты импорта могут раскрыть устройство инфраструктуры. Поэтому защита применяется как к содержимому графа, так и к учётным данным, резервным копиям и журналам. Режим хранения ключей выбирается для фактической среды развёртывания; ключ не размещается рядом с зашифрованной копией данных.

Таблица 4 – Шифрование данных и управление ключами

Данные / участок	Защита	Ключи и порядок обращения
Клиент — сервер	TLS 1.3; AES-256-GCM; проверка сертификата; X25519 при согласованном наборе	Закрытый ключ сертификата хранится в защищённом хранилище сервера; сертификаты отзываются при компрометации
База и резервная копия	AES-256-GCM на уровне тома или приложения; резервная копия шифруется до передачи на носитель	Ключ данных отдельно от копии; обёрнутый ключ в KMS организации или хранилище секретов ОС
Пароли и токены	Пароли — Argon2id с индивидуальной солью; токены — AES-256-GCM	Пароли необратимы; мастер-ключ ограничен учётной записью сервера и недоступен клиенту
Пакеты и импортированные файлы	SHA-256 для контроля целостности; подпись обновлений проверяется открытым ключом издателя	Приватный ключ подписания хранится у издателя; контрольная сумма не заменяет проверку формата и содержимого

Для локального развёртывания мастер-ключ хранится в TPM или системном хранилище секретов ОС с доступом только у серверного процесса. В облачном развёртывании используется KMS выбранного поставщика с отдельной политикой доступа. Ключи не включаются в исходный код, журналы, контейнерный образ или конфигурацию импорта. Ротация выполняется не реже одного раза в год и немедленно при подозрении на утечку; старый ключ удаляется только после успешного перешифрования и проверки резервной копии. Доступ к ключам журналируется.

Для AES-256-GCM используется уникальный nonce при каждом шифровании одним ключом. Пароль не хранится в обратимо зашифрованном виде. Параметры Argon2id настраиваются по возможностям сервера так, чтобы замедлять перебор, не создавая чрезмерной нагрузки. Криптографические операции выполняются проверенной библиотекой; собственные алгоритмы шифрования не разрабатываются.

4 Схема аудита

Сервер записывает события в структурированном формате с временем UTC, идентификатором запроса, псевдонимизированным идентификатором субъекта, организацией и сегментом, типом действия, результатом и кодом причины. В журнал не включаются пароли, токены, полные выгрузки топологий и секреты подключения. Для диагностики фиксируются только объём данных и агрегированные показатели нагрузки.

Таблица 5 – События аудита, сроки хранения и права доступа

События	Приёмник	Хранение и доступ
Входы, выходы, ошибки аутентификации; изменение ролей	Центральный журнал аудита; защищённая передача по TLS	Не менее 180 суток; чтение аудитору и администратору безопасности; экспорт аудируется
Просмотр сегмента, поиск и экспорт топологии	Журнал API с идентификатором запроса и объёмом выдачи	180 суток; аналитик видит свои действия, аудитор — события организации
Импорт, отказ проверки, превышение лимита, подозрение на XSS	Журнал сервера и сигналы мониторинга	Не менее 180 суток; доступ команде безопасности; без сохранения вредоносного содержимого целиком
Изменение конфигурации, отказ базы, ротация ключей и резервное копирование	Неизменяемое хранилище событий или локальный append-only журнал	365 суток; доступ оператора безопасности; удаление по регламенту с отдельной записью

Журналы направляются в корпоративную систему мониторинга безопасности (SIEM) по аутентифицированному шифрованному каналу; если SIEM недоступна, события временно буферизуются локально с ограничением объёма и защитой от изменения. Переполнение очереди создаёт оповещение. Пользователи не могут читать общий журнал; администраторы приложения не могут незаметно менять записи аудита. Сроки хранения являются проектными значениями и уточняются политикой организации и применимыми требованиями.

5 План отказоустойчивости

Сбои не должны превращать ошибку в обход контроля доступа или бесконечную ресурсоёмкую обработку. Сервер использует тайм-ауты, лимиты параллельных задач, ограниченное число повторов и circuit breaker для зависимостей. Повторная выдача команды или выгрузки выполняется только после проверки идентификатора операции и её результата.

Таблица 6 – Отказы сети, API и базы данных

Компонент / отказ	Поведение	Безопасное состояние и восстановление
Клиент или сеть	Запрос прерывается; локально доступные ранее данные не расширяют права	Повторный вход после восстановления; новая проверка прав и актуальности данных
Сервер API перегружен или недоступен	Новые запросы ограничиваются; срабатывает circuit breaker	Нет частичного ответа; очередь ограничена; после восстановления запросы проходят повторную авторизацию
База данных недоступна	Выдача и изменение топологии прекращаются	Нет кэша с более широкими правами; восстановление после проверки целостности и миграций

Таблица 7 – Отказы импорта, отрисовки и аудита

Компонент / отказ	Поведение	Безопасное состояние и восстановление
Импорт или расчёт размещения графа	Задача завершается по тайм-ауту или лимиту памяти; файл не публикуется	Изолированный процесс останавливается; временные данные удаляются; пользователь получает код ошибки
WebGL или графический драйвер	3D-отрисовка отключается или перезапускается	Доступен облегчённый список/табличный просмотр; сервер и исходные данные остаются целыми
SIEM или журнал недоступен	События буферизуются; при исчерпании лимита блокируются опасные изменения и экспорты	Чтение разрешённых данных может продолжаться; накопленный журнал отправляется после восстановления

Лимиты на число узлов и связей задаются для каждого уровня доступа и типа операции; тяжёлый расчёт выполняется в изолированной задаче, а не в основном потоке API. Если рендеринг на устройстве завершается с ошибкой, пользователь может перейти к облегчённому представлению графа. При отказе журнала система сохраняет возможность чтения лишь там, где событие доступа уже надёжно записано; экспорт и административные изменения приостанавливаются.

ЗАКЛЮЧЕНИЕ

Для системы 3D-визуализации определены границы между внешними данными, клиентом, сервером и базой топологий. Проверки на переходах включают аутентификацию, разграничение организаций и сегментов, валидацию импортов, лимиты запросов и защиту от выполнения сценариев в интерфейсе. Матрица RBAC/ABAC задаёт права администраторов, аналитиков, наблюдателей, аудиторов и сервисных компонентов.

План предусматривает TLS 1.3 при передаче, AES-256-GCM для данных при хранении, Argon2id для паролей и раздельное хранение ключей. Журнал аудита фиксирует чтение и экспорт топологий, изменения прав, импорты и отказы. При отказах сети, API, базы, графического клиента или подсистемы аудита система ограничивает обработку, не расширяет права и не публикует непроверенные данные.